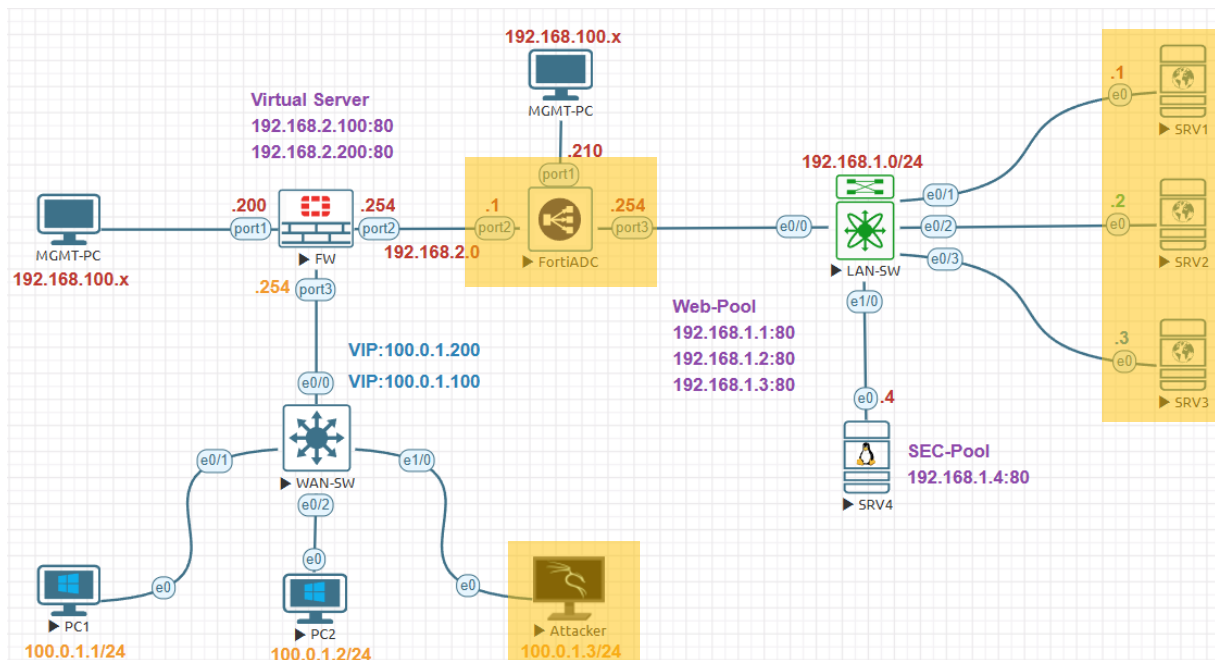


Cookie-Based Persistence Lab:



Management Subnet	192.168.100.0/24
FortiGate Management IP	192.168.100.200
FortiADC Management IP	192.168.100.210
Internal Servers Subnet	192.168.1.0/24
FortiADC External Subnet	192.168.2.0/24
FortiGate Firewall External	100.0.1.0/24
FortiADC Internal IP Address	192.168.1.254
FortiADC External IP Address	192.168.2.1
FortiGate Firewall Internal IP	192.168.2.254
FortiGate Firewall External IP	100.0.1.254
SRV1 IP Address	192.168.1.1
SRV2 IP Address	192.168.1.2
SRV3 IP Address	192.168.1.3
SRV3 IP Address	192.168.1.4
Virtual Sever-1	192.168.2.100
Virtual Sever-2	192.168.2.200
FortiGate VIP-1	100.0.1.100
FortiGate VIP-2	100.0.1.200
External PC1 IP Address	100.0.1.1
External PC2 IP Address	100.0.1.2
External PC3 IP Address	100.0.1.3

Click **Server Load Balance > Application Resources**, and then select the **Persistence** tab.

The screenshot shows the FortiGate web interface. On the left, the 'Server Load Balance' menu is highlighted, and the 'Application Resources' sub-menu is selected. On the right, the 'Persistence' tab is active, displaying a table of persistence methods. The table has two columns: 'Name' and 'Type'.

Name	Type
LB_PERSIS_SRC_ADDR	Source Address
LB_PERSIS_HASH_SRC_ADDR	Source Address Hash
LB_PERSIS_HASH_SRC_ADDR_PORT	Source Address-Port Hash
LB_PERSIS_HASH_COOKIE	Cookie Hash
LB_PERSIS_SSL_SESS_ID	SSL Session ID
LB_PERSIS_SIP_CALL_ID	SIP Call ID
LB_PERSIS_RDP_COOKIE	RDP Cookie

Click **Create New** to create a new persistence method using the following settings:

Name: **Insert-Cookie-Persistence**

Type: **Insert Cookie**

Keyword: **TestCookies**

Timeout (sec): **6**

The screenshot shows the 'Persistence' configuration form. The fields are as follows:

- Name: Insert-Cookie-Persistence
- Type: Insert Cookie
- Keyword: TestCookies
- Timeout: 6
- Domain: Specify the domain.
- Httponly: ☐
- Secure: ☐
- Samesite: Nothing
- Custom Attribute: ☐

At the bottom right, there is a red arrow pointing to the 'Save' button.

Click **Save**

Click **Server Load Balance > Virtual Server>Virtual Server**. Click the edit icon or double click to edit the new virtual server **WEB-VS**.

Virtual Server					Content Rewriting	Content Routing	NAT Source Pool	Schedule Pool
Delete + Create New Search								
+ Add Filter								
Name	Type	Address	Port	Profile				
WEB-VS	Layer 4	192.168.2.100	80	LB_PROF_TCP				
SEC-VS	Layer 7	192.168.2.200	443	LB_PROF_HTTPS				

On the **General** tab, change the **Persistence** setting to **Insert-Cookie-Persistence**, and then click **Save**.

Virtual Server

Basic

General

Security

Application Optimization

Monitoring

Configuration

Address

192.168.2.100

Example: 192.0.2.1

Port

80

Default: 80 Range: 0 or 1-65535. You can specify up to eight ports or port ranges separated by space, e.g., 80-90 100. Valid values are from 0 to 65535, with 0 for Layer-4 virtual servers only.

Connection Limit

0

Default: 0 Range: 0-100000000 concurrent connections

Interface

port2

Resources

Profile

LB_PROF_HTTP

Persistence

Insert-Cookie-Persistence

Method

LB_METHOD_ROUND_ROBIN

Real Server Pool

WEB-Pool

Clone Pool

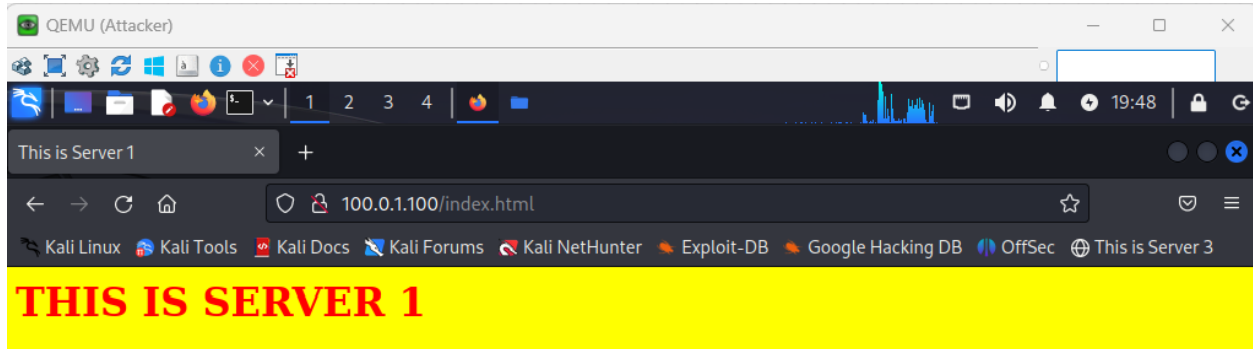
Click to select

Auth Policy

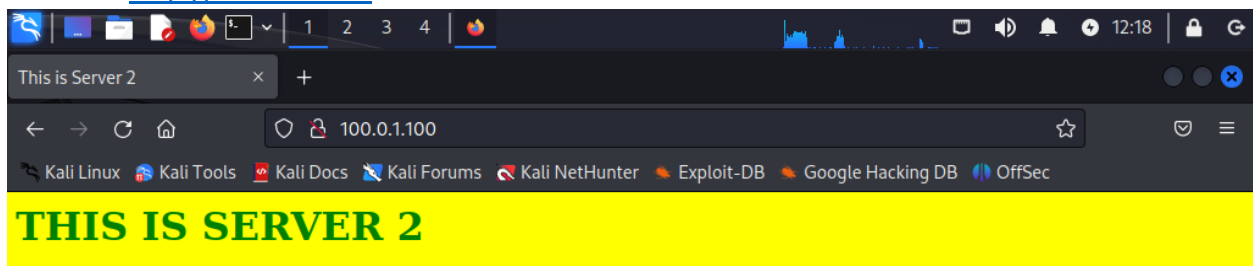
Click to select

Test Cookie-Based Persistence:

On the External Kali Linux, open Firefox, and then connect to the virtual server at <http://100.0.1.100> . Press **CTRL+SHIFT+R** several times to refresh the browser. Traffic is routed to the same application server.



Close the browser wait for 6 seconds., open Firefox, and then connect again to the virtual server at <http://100.0.1.100> . Press **CTRL+SHIFT+R** several times to refresh the browser.



Navigate to **Log & Report > Traffic Log** can verify the same server in this case **SRV2** is hitting.

Dashboard	>	Download	Refresh	SLB Layer 4&2	25/01/04 12:09:00 - 25/01/06 20:08:40
Security Fabric	>	Add Filter			
FortiView	>				
System	>				
Shared Resources	>				
Network	>				
Server Load Balance	>				
Link Load Balance	>				
Global Load Balance	>				
Web Application Firewall	>				
Network Security	>				
DoS Protection	>				
User Authentication	>				
Log & Report	>				
Traffic Log					

Source	Destination	Virtual Server	Duration (s)	Trans Destination	Real Server
100.0.1.3	192.168.2.100	WEB-VS	7	192.168.1.2	SRV2
100.0.1.3	192.168.2.100	WEB-VS	3	192.168.1.2	SRV2
100.0.1.3	192.168.2.100	WEB-VS	3	192.168.1.2	SRV2
100.0.1.3	192.168.2.100	WEB-VS	3	192.168.1.2	SRV2
100.0.1.3	192.168.2.100	WEB-VS	3	192.168.1.2	SRV2
100.0.1.3	192.168.2.100	WEB-VS	3	192.168.1.2	SRV2
100.0.1.3	192.168.2.100	WEB-VS	3	192.168.1.2	SRV2
100.0.1.3	192.168.2.100	WEB-VS	3	192.168.1.2	SRV2
100.0.1.3	192.168.2.100	WEB-VS	4	192.168.1.2	SRV2
100.0.1.3	192.168.2.100	WEB-VS	7	192.168.1.3	SRV3

Also can verify by packet capture on FortiADC CLI using command:

diagnose sniffer packet any "port 80" 4

```
FortiADC # diagnose sniffer packet any "port 80" 4
interfaces=[any]
filters=[port 80]
0.821711 port2 in 100.0.1.3.35720 -> 192.168.2.100.80: ack 676673849
0.821988 port2 out 192.168.2.100.80 -> 100.0.1.3.35720: ack 1942361658
3.818587 port2 in 100.0.1.3.35720 -> 192.168.2.100.80: fin 1942361658 ack 676673849
3.819194 port2 out 192.168.2.100.80 -> 100.0.1.3.35720: fin 676673849 ack 1942361659
3.820724 port2 in 100.0.1.3.35720 -> 192.168.2.100.80: ack 676673850
3.825482 port2 in 100.0.1.3.49018 -> 192.168.2.100.80: syn 4065807670
3.826147 port2 out 192.168.2.100.80 -> 100.0.1.3.49018: syn 117275594 ack 4065807671
3.827110 port2 in 100.0.1.3.49018 -> 192.168.2.100.80: ack 117275595
3.828003 port2 in 100.0.1.3.49018 -> 192.168.2.100.80: psh 4065807671 ack 117275595
3.829597 port3 out 192.168.1.254.46360 -> 192.168.1.2.80: syn 745026432
3.831510 port3 in 192.168.1.2.80 -> 192.168.1.254.46360: syn 2139419094 ack 74502643
3.831696 port3 out 192.168.1.254.46360 -> 192.168.1.2.80: psh 745026433 ack 21394190
3.835395 port3 in 192.168.1.2.80 -> 192.168.1.254.46360: ack 745026828
3.841571 port3 in 192.168.1.2.80 -> 192.168.1.254.46360: psh 2139419095 ack 74502682
3.846634 port2 out 192.168.2.100.80 -> 100.0.1.3.49018: psh 117275595 ack 4065808090
3.847757 port2 in 100.0.1.3.49018 -> 192.168.2.100.80: ack 117276058
3.882439 port3 out 192.168.1.254.46360 -> 192.168.1.2.80: ack 2139419515
3.950269 port2 in 100.0.1.3.49018 -> 192.168.2.100.80: psh 4065808090 ack 117276058
3.950437 port3 out 192.168.1.254.46360 -> 192.168.1.2.80: psh 745026828 ack 21394195
3.951926 port3 in 192.168.1.2.80 -> 192.168.1.254.46360: psh 2139419515 ack 74502717
3.951977 port3 out 192.168.1.254.46360 -> 192.168.1.2.80: ack 2139419962
3.952113 port2 out 192.168.2.100.80 -> 100.0.1.3.49018: psh 117276058 ack 4065808460
3.954497 port2 in 100.0.1.3.49018 -> 192.168.2.100.80: ack 117276505
4.491573 port2 in 100.0.1.3.49018 -> 192.168.2.100.80: fin 4065808460 ack 117276505
4.491631 port2 out 192.168.2.100.80 -> 100.0.1.3.49018: fin 117276505 ack 4065808461
4.491703 port3 out 192.168.1.254.46360 -> 192.168.1.2.80: rst 745027174 ack 21394199
```

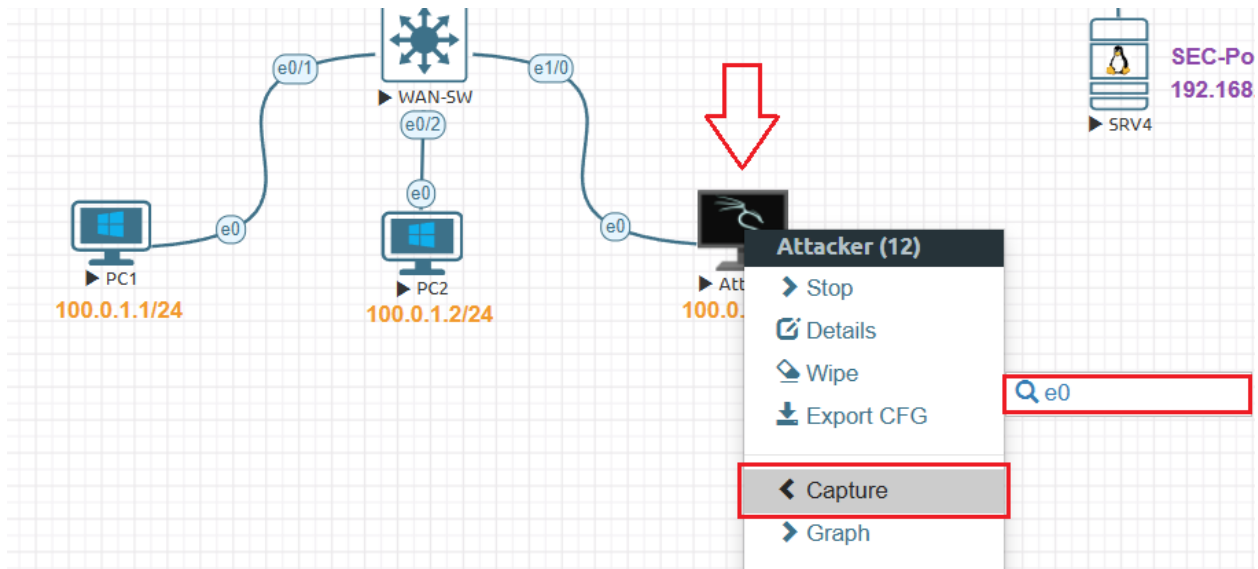
In Mozilla Firefox Browser Right click goes to **inspect>Storage>Cookies** to verify as well

The screenshot shows a Mozilla Firefox browser window with the address bar displaying '100.0.1.100/index.html'. The page content is a solid yellow background with the text 'THIS IS SERVER 1' in red. The Storage Inspector is open, showing a table of cookies. A yellow arrow points to the cookie entry for 'TestCookies'.

Name	Value	Domain	Path	Expires / Max-Age	Size	HttpOnly
TestCookies	rs1Z9TAm	100.0.1.100	/	Session	20	false

The right pane of the Storage Inspector shows the details for the 'TestCookies' cookie:

- Created: "Fri, 14 Mar 2025 23:48:41 GMT"
- Domain: "100.0.1.100"
- Expires / Max-Age: "Session"
- HostOnly: true
- HttpOnly: false
- Last Accessed: "Fri, 14 Mar 2025 23:49:41 GMT"
- Path: "/"
- SameSite: "None"
- Secure: false
- Size: 20



25	4.005794438	100.0.1.100	100.0.1.3	TCP	66 80 → 44824 [FIN, ACK] Seq=909 Ack=791 Win=3123
26	4.005890689	100.0.1.100	100.0.1.3	TCP	74 80 → 44826 [SYN, ACK] Seq=0 Ack=1 Win=28960 Le
27	4.005942171	100.0.1.3	100.0.1.100	TCP	66 44824 → 80 [ACK] Seq=791 Ack=910 Win=64128 Len
28	4.005965458	100.0.1.3	100.0.1.100	TCP	66 44826 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 T
29	4.006098367	100.0.1.3	100.0.1.100		
30	4.011589913	100.0.1.100	100.0.1.3		
31	4.011893829	100.0.1.3	100.0.1.100		
32	4.044721660	100.0.1.3	100.0.1.100		
33	4.047038432	100.0.1.100	100.0.1.3		
34	4.088353141	100.0.1.3	100.0.1.100		

▶ Frame 29: 485 bytes on wire (3880 bits), 485 bytes captured (3880 bits) on e0	
▶ Ethernet II, Src: 50:00:00:0c:00:00 (50:00:00:0c:00:00), Dst: 50:00:00:0c:00:00 (50:00:00:0c:00:00)	
▶ Internet Protocol Version 4, Src: 100.0.1.3, Dst: 100.0.1.100	
▶ Transmission Control Protocol, Src Port: 44826, Dst Port: 80, Seq: 66, Len: 0	
▶ Hypertext Transfer Protocol	

HTTP Stream	Ctrl+Alt+Shift+H
TCP Stream	Ctrl+Alt+Shift+T

```

Attacker_e0
GET /index.html HTTP/1.1
Host: 100.0.1.100
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Cookie: TestCookies=rs3|Z9TDh
Upgrade-Insecure-Requests: 1
Pragma: no-cache
Cache-Control: no-cache

HTTP/1.1 200 OK
Date: Fri, 14 Mar 2025 21:02:00 GMT
Server: Apache/2.4.18 (Ubuntu)
Last-Modified: Sun, 09 Mar 2025 16:28:30 GMT
ETag: "9a-62feb589e3800-gzip"
Accept-Ranges: bytes
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 141
Content-Type: text/html
  
```